

组会进展汇报 · 2026-08-18

Agent 扩展授权中的 制品身份漂移

Goose v1.45.0 Case Study 与多框架 Benchmark 计划

Artifact Identity Binding in Agent Extension Activation

受测系统 Goose v1.45.0 · Linux CLI · Auto (默认模式)	结论上限 Level 2 authorization-reference drift	正式运行 5 / 15 (R1×3 + R2×2)	待执行 R3–R6 · VM 已 hibernate
--	--	-------------------------------------	--------------------------------------

一句话发现与当前阶段

D1 §1-§6 | R1组 §2 | R2组 §6

受控实验中，Goose 在准入（admission）时授权的对象是一个**可变选择器** `npx -y goose-activation-canary@latest`；激活（activation）前，同一引用被重指向制品 **B** 并被**原样执行**——配置文本逐字节未变，且未出现针对具体制品的任何新授权。

严谨名称： authorization-reference drift · deferred-resolution authorization D1 §0

Level 2

结论上限：漂移成立；Level 3（TOCTOU）判据缺失，不使用该词

D1 §6

5 / 15 上限

正式运行：R1-1 / R1-2 / R1-3 / R2-1 / R2-2；停止条件均未触发

R2组 §6

4 + 2

漂移观测 4 次（D1+R1）；exact-version 阴性对照 2 次未漂移

R1组 §2 | R2组 §2

R3–R6

全部未执行；VM 已 hibernate，R3a readiness 恢复后不可直接复用

P50 A1.6 | R3a-H

研究动机：Agent 授权的对象究竟是什么？

SRC §2·§4·§6

“启用一个扩展”时，系统各环节实际持有的是哪一层身份？

L1 · 名称 **extension name** 发现与选择向模型暴露的唯一信息（name + description）

L2 · 命令行 **cmd + args** 配置与授权的载体：npx -y pkg@latest

L3 · 版本 **version** OSV 信誉查询输入；latest 被源码显式归约为“无版本”

L4 · 制品 **最终执行的 artifact 内容** 只在 Goose 进程之外、activation 阶段由 npx 确定的字节 ?

研究问题

SRC §3

当授权与检查建立在 **L1–L3**，而实际执行的是 **L4**：在**名称保持不变**的前提下，控制链路的任何一环能否**察觉最终制品身份的变化**？

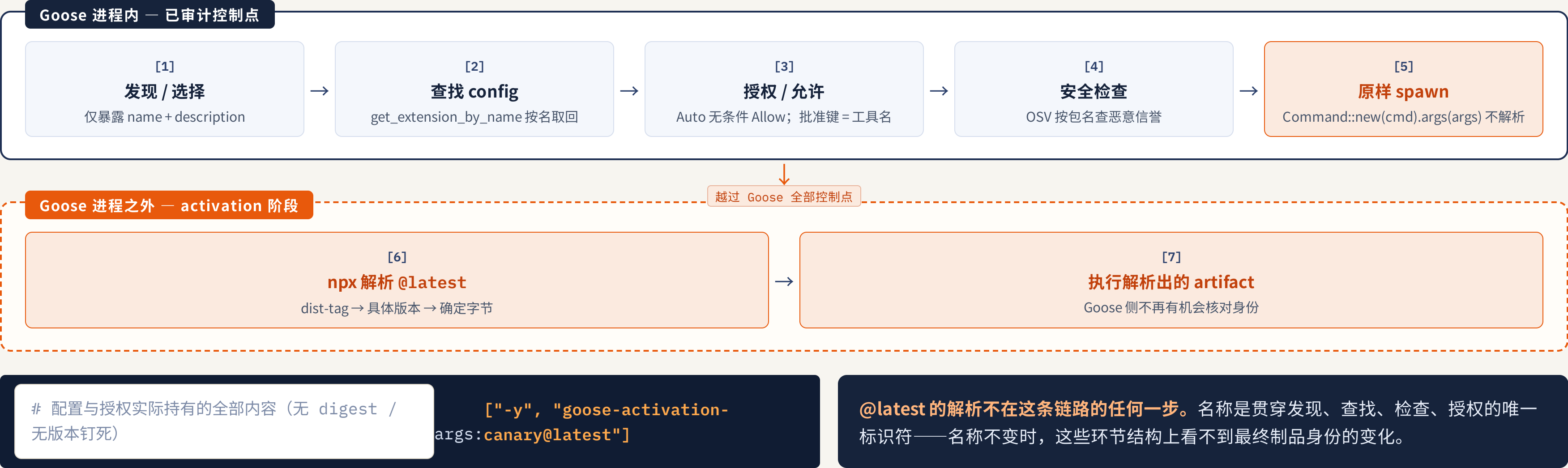
本研究给出的初步回答

D1 §6 | R1组 §2

在 Goose v1.45.0 的 stdio extension 激活路径上：**不能**。admission 观测制品 A → activation 执行制品 B，全程无 artifact-specific 新授权。

Goose 扩展启用的内部机制链

SRC §2 (含行号) · commit 4dc0420f5704



威胁模型与本地良性 A/B canary

D1 §2.3·§3·§8

威胁模型

idea/48 §3

- 1

攻击者能力：控制 registry 的 dist-tag 指向（registry 投毒 / 账号劫持 / 同名抢注），可在 admission 与 activation 之间重指向，且**无需触碰本地任何配置**。
- 2

用户行为：按名称登记并启用扩展（官方文档路径），配置为指向可变 tag 的选择器——用户以为批准的是“那个扩展”。
- 3

攻击结果：activation 时解析到不同制品并执行；授权、检查、持久化状态均不发生变化。

canary 制品设计

D1 §2.3

制品 A	1.0.0 • sha256 cfb882e2deec...
制品 B	1.0.1 • sha256 081c9afc7b71...
tool surface	A / B 的 tools/list 逐字节相同 (29c2a28b...)
行为差异	仅自报身份与效应文件名（canary-A / canary-B）
capability effect	进程启动即向隔离目录 O_EXCL 写固定文件

安全信封（全部遵守）

D1 §8

- ✓

良性制品：不联网、不读凭据、不访问任何真实服务
- ✓

registry 为本机 loopback 自建，**从未发布到任何真实 registry**
- ✓

产品原生 OSV 外呼被 harness 阻断并验证（R1 起）
- ✓

停止规则触发即停，未扩大测试面

D1：盲发现与 Level 1 / 2 / 3 判据

D1 §4.1·§5·§6 | idea/48 §2

D1 事件时间线（同源纳秒时戳）

D1 §4.1

- ...961.50
registry_start — 本地测试 registry 启动，latest → 1.0.0
- ...962.95
admission：研究者解析选择器 → **制品 A**（cfb882e2deec...）；extension 以 enabled:false 写入配置
- ...963.36
dist_tag_repointed: latest 1.0.0 → 1.0.1（配置文件未改动）
- ...963.37
goose_start — 单条明确指令驱动启用扩展
- ...974.31
process_spawned — npx（父进程为 goose）
- ...974.51
packument_fetch — npx 看到 latest=1.0.1（tarball 命中本地缓存）
- ...974.63
effect_B_process_start ★ 预注册 capability effect 即刻产生
- ...984.48
effect_B_first_tool_execution — 比 process_start 晚约 9.85 s

LEVEL 1 顺序结果

成立（附条件）

capability effect 先于该 extension 首个工具执行约 **9.85 s**；但 Auto 模式全程无批准提示 → 记 no_first_tool_approval_in_profile，不得称“绕过了批准”。

LEVEL 2 authorization-reference drift

成立

四条件合取：admission 观测 A ∧ activation 执行 B ∧ 授权仅绑定可变选择器 ∧ 全程无针对制品的新授权。

LEVEL 3 TOCTOU 候选

不成立

缺 SystemCheckedOrBound(A)：无证据表明系统曾解析并绑定 A 的 digest。
admission_resolution = unobservable, system_bound_digest = absent → 不使用 TOCTOU 一词。

证据完整性：外层 frozen manifest **30 OK / 0 FAILED**；内层 28 OK / 1 FAILED（run.log 追加行，已确定性证明为器材顺序缺陷，非篡改）。

源码根因：授权对象在类型层面无法表达制品身份

SRC §3-§6 | SRC-ADD A2·A3

ExtensionConfig::Stdio

extension.rs:176 — 扩展配置

name

description

cmd

args

envs

timeout

digest

checksum

signature

publisher

version-lock

四文件全文检索 sha256|digest|signature|verify_hash|checksum → 0 命中

CanonicalGrant (观测到的)

D1 § 5.2 — 持久化授权表达

cmd: npx

args: ["-y", "...@latest"]

无 digest、无版本钉死（保守表述：本 profile 中观测到的全部）

ToolPermissionRecord

permission_store.rs:12 — 批准存储

key = tool_name

extension

artifact

一次 AlwaysAllow 覆盖未来所有 extension 的启用操作

pre-spawn OSV 检查 — 有效，但解决的是另一个问题

SRC §4 | SRC-ADD A2

✓ 对 恶意包信誉筛查 有效：名称（及可用版本）命中 MAL - 通告即拒绝启动——设计者认真对待了这层风险

△输入是同一个可变选择器：源码显式把 latest 归约为 version: None，只按名查询

✗ 与 artifact identity binding 正交：查询不涉内容，无法区分同名不同内容；网络/HTTP/JSON 失败均 fail-open

解析时点

SRC §2

▪ Goose 把 cmd 与 args 原样交给 Command::new

▪ @latest 由 npx 在 Goose 进程之外、spawn 之后解析

▪ 位于 Goose 所有已审计控制点之后

配置与权限记录合起来仍缺少一个能指称已解析制品的字段——这不是“忘了校验”，而是授权对象的类型里没有可供校验的字段。（≠ “Goose 没有安全检查”）

SRC-ADD A3

R1： 漂移的重复性结果

R1组 §0·§2·§5 | R1-1 §4

运行	证据类别（不得合并计数）	admission 观测	dist-tag 变化	RuntimeArtifact	L1 间隔	Level 2
D1	A • preregistered（盲） 不计入本协议	A (1.0.0)	1.0.0→1.0.1	canary-B	~9.85 s	成立
R1-1	B • 带偏差（A5.6 并发） 永久不计入	A (1.0.0)	1.0.0→1.0.1	canary-B	~9.99 s	成立
R1-2	C • 前瞻符合 conforming #1（rig v8）	A (1.0.0)	1.0.0→1.0.1	canary-B	9.9237 s	成立
R1-3	C • 前瞻符合 conforming #2（rig v9）	A (1.0.0)	1.0.0→1.0.1	canary-B	6.6169 s	成立

R1-1 偏差性质：Goose 自身并发发起 session-naming 辅助请求（vLLM Running：2），违反 A5.6 “一次一个请求”；属受测产品自身行为，非器材并行。对判据依据（制品身份 / effect 时戳 / 授权对象）无影响，但协议层效力不由执行者裁定。

controlled-warm 证据完整性差异（必须披露）：D1 / R1-1 未捕获 pre-activation 证据；R1-2 / R1-3 完整捕获（预热日志分段保存 + registry 确认 081c9afc... + 缓存清点 7/7）。**✗ 不得回溯补造。**

⚠ 计数纪律：R1-2 / R1-3 为 两次前瞻符合协议的重复（上限） —— 不得声称 N = 3 ，不得把 D1 与本协议运行混列不加区分。

R2: exact-version 阴性对照 (×2, 一致)

R2组 §0·§2·§4 | R2-1·R2-2 §2

R1 臂 · 可变选择器

R1组 §2

Auto · ...@latest · controlled-warm (预热 B)

B RuntimeArtifact = canary-B
漂移发生 (4 次观测: D1 + R1×3)

R2 臂 · 精确版本

R2-1·R2-2 §1

Auto · ...@1.0.0 · cleared (空缓存) —— 参数逐字段相同 ×2

A RuntimeArtifact = A (1.0.0) 两轮一致
漂移未发生 (阴性对照成立)

唯一允许的表述: 在该受控 registry 环境中, 精确版本阻止了 dist-tag 漂移——repoint 后解析器**看到** latest=1.0.1 仍取回 1.0.0 (tarball_fetch cfb882e2deec...)。

✗ 版本号 ≠ 内容摘要: 同版本号重发布为不同字节的情形本实验未测 (属 R3 content-bound 臂); ✗ 非因果证明: R1↔R2 同时存在 selector 形式 + 缓存条件两个差异, 需 R4 (mutable + cleared) 分离。

执行制品 A 的五条独立证据 (两轮一致)

R2组 §2

- 1 效应文件: effect_A_* 三件, canary_id="A"、server_version="canary-A"
- 2 安装树元数据: canary_identity.json → "A"; package.json → 1.0.0
- 3 registry 访问日志: tarball_fetch ...-1.0.0.tgz (cfb882e2deec…), 同窗 packument 均 latest=1.0.1
- 4 MCP 会话输出: [canary-A] ping; canary-B 出现 0 次
- 5 per-run 缓存内容: _cacache 仅含 A 的 tarball (3407 B), 无 B

顺序与授权观测同 R1: L1 成立 (附 no_first_tool_approval_in_profile) · 批准提示 0 · session_scoped · admission_resolution=unobservable · 证据完整性 frozen 52 OK / inner 51 OK (0 FAILED, ×2)。

当前证据能说什么、不能说什么

✓ 可以主张（均有冻结证据）

Level 2 漂移成立：4 次观测 + 2 次前瞻符合协议的重复 R1组 §2

源码层根因：授权对象类型无制品字段；@latest 在全部控制点之后解析 SRC §3

阴性对照相容性：R2 结果与“漂移由可变 tag 承载”相容（非因果证明） R2组 §5

证据链完整：冻结 + 双层哈希 + 只读归档；除 D1 内层已证顺序缺陷外全部 0 FAILED R1组 §3

宿主路径确定性（附条件）：固定外部条件时，已审计代码路径未发现不确定性分支 SRC-ADD A4

✗ 不能声称（证据不支持 / 明确错误）

TOCTOU — 缺 SystemCheckedOrBound(A)；admission_resolution = unobservable D1 §6

arbitrary code execution / 可利用漏洞 / 高危定级 D1 §0

“绕过了 artifact-specific 用户批准” — Auto 模式本无批准环节 D1 §6

跨框架 / 跨系统普遍性 — 单产品、单版本、单配置 SRC §9

N = 3 protocol-conforming repetitions R1组 §0

exact-version = 内容完整性保证；R1→R2 因果证明 R2组 §0

R3–R6：后续实验矩阵（全部待确认后执行）

P50 §6 + A1.3/A1.4/A1.6 | R3a-H

ID	目的	模式	selector 臂	cache	次数	状态
R3a	功能对照	Auto	content-bound：解析到 A，期望 A	cleared	1	未执行 VM hibernate，readiness 需重建
R3b	拒绝对照	Auto	content-bound：解析到 B，期望 A	cleared	1	未执行
R4	准入解析探针	Auto	mutable (@latest)	cleared	2	未执行 与 R2 构成单差异对照
R5	批准内容	Approve	mutable • Allow Once / Always Allow 各一	cleared	2	未执行 分别报告显示/选择/持久化
R6	批准内容	Smart	mutable • 同 R5 操作冻结	cleared	2	未执行

R3 配对判读规则（缺一不可）

P50 A1.3

R3a • digest-match

期望 A / 实际 A → 放行，A 正常启动并产生预注册 A effect

∧

R3b • digest-mismatch

期望 A / 实际 B → B 执行前拒绝（冻结退出码 4），不产生任何 B effect

仅 **R3a pass** ∧ **R3b reject** 同时成立 ⇒ content binding 有效；**仅 R3b 拒绝不能排除 fail-closed-by-breakage**（wrapper 损坏也会“拒绝”）。该 adapter 是**外部 custom adapter**，非 **Goose 原生防御**。

R4 认识论边界（预先冻结）

P50 §6.1

- ✓ 可观测 manage_extensions 之前 registry 日志是否出现请求
- ✗ 零 registry 流量 ≠ 系统未执行解析（可能经未观测路径）
- ✗ 不得据此把 admission_resolution 收敛为 not_performed，无正面证据时保持 unobservable

从 Goose case study 到多框架 benchmark

PROPOSED — 设计中，未开始

导师建议的方向：使用**统一的受控 attack / workload**， 测量多个开源 Agent 框架对 **artifact identity drift** 的抵抗能力。

D1 是否允许 mutable selector	D2 selector 在哪个生命周期阶段解析	D3 admission 是否解析 artifact
D4 DisplayedGrant 显示名称 / 版本 / digest	D5 CanonicalGrant 实际绑定什么	D6 activation 前是否重新授权
D7 是否验证版本 / digest / 签名 / provenance	D8 Auto / Approve / Smart 等模式的差别	D9 actual RuntimeArtifact 是否可观测
D10 exact-version 与 content-bound 防御是否有效	D11 失败时 fail-open 还是 fail-closed	? 评分制与首批框架 —— 待组会讨论（见第 14 页）

Goose case study 为上述维度提供了一套完整的构造方法与判读纪律（canary / 三态观测 / 配对对照 / 停止规则）； benchmark 将复用该方法而非仅复用结论。

局限、披露与研究伦理

当前结论的边界

SRC §11 | SRC-ADD A6

- ✗ **单产品、单版本、单配置**：Goose v1.45.0 CLI • Auto • stdio extension 路径
- ✗ **源码 ↔ 受测二进制仅版本号对应**，未做 reproducible-build 级验证
- ✗ **仅审计 stdio 路径**：GUI/Desktop、streamable_http、recipe / plugin / skills 未覆盖
- ✗ **LLM 步骤确定性未证明**：模型是否发出 manage_extensions 涉及 N=1 决策
- ✗ **R1↔R2 双差异未分离**（selector 形式 × 缓存条件），因果归因需 R4
- ✗ **模型后端两处偏差**：chat template 单条件修改；seed 无法经客户端设置 D1 §2.2

伦理与披露状态

D1 §3·§7·§8 | P50 §8

- ✓ **良性 canary**：仅隔离目录效应，不联网、不读凭据、不访问真实服务
- ✓ **本地 loopback registry**：从未向任何真实 registry 发布或拉取
- ✓ **停止规则优先**：安全信封与停止条件优先于完成重复次数（D1 触发即停）
- ✓ **证据纪律**：逐次冻结 + 双层哈希 + 只读归档；偏差与缺陷一律 erratum，不回溯改写
- ✓ **未联系 vendor**：是否 / 何时 / 以何种形式披露，由导师与机构决定
- ✓ **本材料仅限组会内部讨论**：不公开、不外传，与协调披露时间线保持一致

希望组会讨论的六个决策

研究路线 · 优先级 · 披露时间线

Q1 论文主贡献定位：**单系统机制 case study** 为主，还是**多框架 benchmark** 为主？

Q2 benchmark 第一批应选择**哪些主流开源 Agent 框架**？

Q3 是否**先完成 Goose R3–R6**，再扩展到第二个框架？

Q4 **ordinary-task E2E**（headline PRIMARY 臂，N=10）应何时开展？

Q5 **coordinated disclosure 时间线**如何与投稿计划协调？

Q6 benchmark 评分：**二元 pass / fail**，还是分层 **resistance score**？